





Resumen: Fundamentos de Ciberseguridad

Eric Oswaldo Aguilar Nova - 219635295

Seguridad en Redes e Infraestructura Tecnológica - D01

Mtro. José de Jesús Soto Sanches

Índice

Resumen: Fundamentos de Ciberseguridad 1
Índice 2
Riesgos y seguridad informática 3
Método de análisis de riesgos 4
Técnicas de análisis de riesgos 4
Vulnerabilidades 5
Ética profesional y legalidad 5
Herramientas de seguridad 6
Shodan 6
Advanced Port Scanner 6
Segmentación de red 7
Amenazas tecnológicas en ciberseguridad 7
Ataques de red 8
Técnicas de explotación y exploración de red 9
Ingeniería social 9
Amenazas internas 10
Vulnerabilidades de infraestructura 10
Amenazas a dispositivos 10
Seguridad de endpoints 11
Seguridad en IoT 11
Riesgos para la continuidad operativa 11
Amenazas emergentes 12
Comando netstat -a 12
Modelo OSI 13
Bibliografía: 16

Riesgos y seguridad informática

Concepto de riesgo

En ciberseguridad, el riesgo representa la posibilidad de que una amenaza aproveche una vulnerabilidad y provoque consecuencias negativas sobre un activo de información o sobre la operación de una organización.

Los principales elementos que intervienen en el análisis de riesgos son:

- Activo: recurso que posee valor para una organización, como información, servidores, aplicaciones, equipos, bases de datos o servicios.
- Amenaza: evento, agente o circunstancia que tiene el potencial de causar daño a un activo.
- Vulnerabilidad: debilidad existente en un sistema, proceso, aplicación o infraestructura que puede ser aprovechada por una amenaza.
- Impacto: magnitud de las consecuencias que tendría la materialización de un riesgo.

Una forma simplificada de representar el riesgo es:

$R = A \times V \times I$

Donde:

- R = Riesgo
- A = Amenaza
- V = Vulnerabilidad
- I = Impacto

También puede entenderse de manera conceptual como:

- Amenaza + vulnerabilidad → riesgo

La combinación de una amenaza con una vulnerabilidad permite determinar la probabilidad de que ocurra un incidente.

Riesgo inherente

Es el nivel de riesgo que existe antes de implementar controles de seguridad. Representa la exposición natural de un sistema frente a sus amenazas y vulnerabilidades.

Riesgo residual

Es el riesgo que permanece después de implementar controles de seguridad. Los controles pueden reducir la probabilidad de ocurrencia, el impacto o ambos, pero normalmente no eliminan completamente el riesgo.

Tolerancia al riesgo

La tolerancia al riesgo indica el nivel de riesgo que una organización está dispuesta a aceptar. Puede clasificarse, de manera general, como:

- Bajo: consecuencias y probabilidad reducidas
- Medio: requiere seguimiento y controles adecuados
- Alto: requiere atención prioritaria y medidas de mitigación

Método de análisis de riesgos

Un análisis de riesgos puede dividirse en seis fases principales:

1. **Definir el alcance:**

   Se establece qué sistemas, redes, aplicaciones, instalaciones, procesos y activos serán evaluados.

2. **Identificar los activos:**

   Se identifican los recursos que necesitan protección y se determina su importancia para la organización.

3. **Identificar amenazas:**

   Se determinan las situaciones que podrían afectar a los activos, por ejemplo, programa maligno, accesos no autorizados, ataques de red, fallas eléctricas o errores humanos.

4. **Identificar vulnerabilidades:**

   Se buscan debilidades que puedan ser aprovechadas por las amenazas, como software desactualizado, contraseñas débiles, puertos innecesarios abiertos o configuraciones incorrectas.

5. **Analizar los riesgos:**

   Se evalúa la probabilidad de que una amenaza aproveche una vulnerabilidad y se determina el posible impacto.

6. **Gestionar los riesgos:**

   Se seleccionan medidas para reducir, transferir, evitar o aceptar el riesgo.

Técnicas de análisis de riesgos

Existen principalmente dos enfoques:

- **Análisis cualitativo:**

  Utiliza categorías como bajo, medio y alto para valorar la probabilidad y el impacto. Es sencillo de aplicar y permite priorizar riesgos sin necesidad de utilizar valores monetarios exactos.

- **Análisis cuantitativo:**

  Utiliza valores numéricos para estimar el riesgo. Puede considerar factores como pérdidas económicas, frecuencia de incidentes y costos de recuperación.

Vulnerabilidades

Una vulnerabilidad es una debilidad que puede ser aprovechada para comprometer la seguridad de un sistema.

Por ejemplo:

- Software sin actualizar
- Contraseñas débiles
- Configuraciones incorrectas
- Puertos y servicios innecesarios expuestos
- Falta de cifrado
- Sistemas operativos obsoletos
- Falta de controles de acceso
- Errores de programación
- Falta de mantenimiento

Una vulnerabilidad por sí sola no necesariamente significa que haya ocurrido un ataque, pero aumenta la exposición de un sistema frente a una amenaza.

Ética profesional y legalidad

Las actividades de seguridad informática deben realizarse dentro de un marco ético y legal. Las pruebas de seguridad, escaneos y evaluaciones de vulnerabilidades deben contar con autorización cuando se realizan sobre sistemas que no pertenecen al investigador.

Tipos de hackers

- **White Hat:**

  Profesionales de seguridad que realizan actividades de evaluación y pruebas con autorización, generalmente con el objetivo de encontrar y corregir vulnerabilidades.

- **Black Hat:**

  Personas que utilizan técnicas de hacking sin autorización con fines maliciosos o ilegales, como robo de información, fraude o interrupción de servicios.

- **Grey Hat:**

  Personas que pueden identificar o investigar vulnerabilidades sin contar necesariamente con autorización, aunque sus acciones no siempre tienen una finalidad directamente maliciosa.

Herramientas de seguridad

Nmap: herramienta utilizada para realizar exploración de redes y puertos, identificación de servicios y reconocimiento de dispositivos.

Burp Suite: plataforma utilizada principalmente para realizar pruebas de seguridad en aplicaciones web. Permite analizar y modificar solicitudes HTTP/HTTPS y detectar diferentes tipos de vulnerabilidades.

Metasploit: framework utilizado para desarrollar y ejecutar pruebas de explotación de vulnerabilidades en entornos autorizados.

Wireshark: herramienta para la captura y análisis de tráfico de red. Permite examinar paquetes y protocolos para comprender cómo se comunica un dispositivo dentro de una red.

Shodan

Shodan es un buscador especializado en dispositivos y servicios conectados a Internet. A diferencia de un buscador tradicional, que está orientado principalmente a páginas web, Shodan recopila información sobre servicios y dispositivos que son accesibles desde Internet.

Puede proporcionar información tales como:

- Direcciones IP
- Puertos abiertos
- Servicios disponibles
- Versiones de determinados servicios
- Información sobre servidores
- Banners de servicios
- Sistemas y dispositivos conectados a Internet

Shodan puede utilizarse en reconocimiento de infraestructura, auditorías de seguridad y análisis de exposición de activos.

Un concepto importante es que encontrar un dispositivo en Shodan no significa necesariamente que sea vulnerable. La información obtenida debe analizarse y, cuando se realice una prueba sobre un sistema ajeno, debe existir autorización.

Advanced Port Scanner

Advanced Port Scanner es una herramienta de exploración de redes utilizada para identificar dispositivos y puertos abiertos dentro de una red.

Puede proporcionar la siguiente lista de información:

- Dispositivos detectados

- Direcciones IP
- Puertos abiertos
- Servicios asociados a determinados puertos
- Información básica del dispositivo

Un administrador puede utilizar un escáner de puertos para comprobar si dentro de una red existen servicios que no deberían estar expuestos.

Segmentación de red

La segmentación de red consiste en dividir una red en diferentes segmentos para limitar la comunicación entre ellos y reducir la superficie de ataque. Por lo que una organización puede separar:

- Red administrativa
- Red de servidores
- Red de empleados
- Red de invitados
- Red de dispositivos IoT

Una de sus principales ventajas es que, si un dispositivo resulta comprometido, el atacante puede tener mayores dificultades para acceder al resto de la infraestructura, ya que la segmentación puede implementarse mediante tecnologías como:

- VLAN
- Firewalls
- ACL
- Subredes
- Sistemas de control de acceso

Amenazas tecnológicas en ciberseguridad

Malware: el término malware proviene de malicious software y se utiliza para describir software diseñado para realizar acciones perjudiciales o no autorizadas.

Virus: código malicioso que se adjunta a archivos o programas legítimos y puede ejecutarse cuando el usuario ejecuta el archivo infectado.

Gusano: programa capaz de replicarse y propagarse automáticamente, especialmente a través de redes.

Troyano: programa que aparenta ser legítimo o útil, pero que contiene funciones maliciosas ocultas.

Ransomware: malware que puede cifrar archivos o bloquear el acceso a sistemas y posteriormente exigir un pago para intentar recuperar el acceso.

Spyware: software diseñado para recopilar información sobre las actividades de un usuario sin su conocimiento o consentimiento.

Adware: software que muestra publicidad no deseada o intrusiva. Dependiendo del caso, también puede recopilar información sobre el comportamiento del usuario.

Rootkit: conjunto de herramientas diseñadas para ocultar la presencia de software malicioso y mantener acceso a un sistema. Algunos pueden operar a niveles muy profundos del sistema.

Keylogger: software o mecanismo que registra las pulsaciones del teclado para obtener información introducida por el usuario.

Fileless Attack: ataque que intenta ejecutar código malicioso principalmente en memoria, reduciendo la necesidad de crear archivos maliciosos tradicionales en el disco.

Rogue Software: software que se presenta falsamente como una herramienta legítima, por ejemplo, un supuesto antivirus que informa de problemas inexistentes para engañar al usuario.

Browser Hijacker: software que modifica configuraciones del navegador, como página de inicio, buscador o extensiones, normalmente sin autorización adecuada.

Backdoor: mecanismo que permite mantener o facilitar un acceso no autorizado a un sistema, evitando los mecanismos normales de autenticación o seguridad.

Botnet: red de dispositivos comprometidos que se encuentran bajo el control de un atacante. Estos dispositivos pueden utilizarse para realizar actividades coordinadas, como ataques distribuidos de denegación de servicio.

Cryptojacking: uso no autorizado de los recursos de procesamiento de un dispositivo para realizar minería de criptomonedas.

Zero-Day Exploit: técnica de explotación que aprovecha una vulnerabilidad para la cual todavía no existe un parche disponible o que aún no ha sido solucionada por el fabricante.

Ataques de red

DoS: un ataque de Denial of Service (DoS) intenta provocar que un servicio o dispositivo deje de estar disponible mediante el consumo excesivo de sus recursos.

DDoS: un Distributed Denial of Service (DDoS) utiliza múltiples dispositivos o fuentes para generar tráfico o solicitudes contra un objetivo.

La principal diferencia es que DoS puede originarse desde una fuente principal, mientras que DDoS utiliza múltiples fuentes distribuidas.

Man-in-the-Middle: un ataque Man-in-the-Middle (MitM) ocurre cuando un atacante consigue posicionarse entre dos partes que se están comunicando para interceptar, observar o modificar la comunicación.

ARP Spoofing: técnica en la que se envían respuestas ARP manipuladas para asociar la dirección MAC del atacante con la dirección IP de otro dispositivo.

Esto puede permitir que el tráfico destinado a otro dispositivo pase por el equipo del atacante.

DNS Spoofing: consiste en proporcionar respuestas DNS falsas con el objetivo de hacer que una víctima sea dirigida hacia una dirección diferente de la legítima.

Técnicas de explotación y exploración de red

Captura de paquetes

Consiste en capturar y analizar paquetes que circulan por una red. Herramientas como Wireshark permiten realizar este análisis en entornos autorizados.

Ataques de fuerza bruta

Consisten en realizar múltiples intentos de autenticación utilizando diferentes combinaciones de credenciales hasta encontrar una combinación válida.

Exploración de puertos

Consiste en identificar qué puertos de un dispositivo están abiertos y qué servicios pueden estar asociados con ellos.

Herramientas como Nmap y Advanced Port Scanner pueden utilizarse para esta tarea.

Cross-Site Scripting (XSS)

Vulnerabilidad de aplicaciones web que permite introducir código ejecutable, normalmente JavaScript, en contenido que posteriormente puede ser interpretado por el navegador de otros usuarios.

Ingeniería social

La ingeniería social consiste en utilizar técnicas de manipulación psicológica para conseguir que una persona revele información o realice determinadas acciones.

Phishing

Es una modalidad de ingeniería social en la que un atacante intenta hacerse pasar por una organización o persona legítima para obtener información, credenciales o provocar que la víctima realice una acción.

Ejemplos de objetivos pueden ser:

- Contraseñas
- Datos bancarios
- Códigos de autenticación
- Información personal

Amenazas internas

Las amenazas internas son aquellas que se originan dentro de una organización o involucran a personas que tienen algún nivel de acceso legítimo a sus sistemas.

Abuso de privilegios: ocurre cuando una persona utiliza permisos que posee de manera indebida o excede las funciones para las cuales fueron otorgados.

Empleados descontentos: los conflictos laborales, despidos, problemas internos o inconformidad pueden aumentar el riesgo de que un empleado realice acciones perjudiciales de forma intencional.

Vulnerabilidades de infraestructura

La infraestructura tecnológica también puede presentar riesgos físicos y operativos:

- Fallas de hardware
- Falta de mantenimiento
- Sobrecalentamiento
- Interrupciones eléctricas
- Obsolescencia tecnológica
- Daños físicos en centros de datos
- Fallas en sistemas de refrigeración
- Problemas de conectividad

Estas situaciones pueden provocar interrupciones de servicios incluso cuando no existe un ataque informático.

Amenazas a dispositivos

Los dispositivos físicos también pueden ser manipulados para obtener información.

Skimmer

Un skimmer es un dispositivo o mecanismo utilizado para capturar información de tarjetas de pago, especialmente en determinados lectores de tarjetas. Puede utilizarse de forma fraudulenta para obtener datos financieros.

Seguridad de endpoints

Un endpoint es un dispositivo final conectado a una red, como una computadora, laptop, teléfono o dispositivo especializado.

Una medida importante de protección es el cifrado de disco, que permite proteger la información almacenada en el dispositivo.

Ejemplos:

- BitLocker en Windows
- FileVault en macOS

El cifrado ayuda a proteger los datos en caso de pérdida o robo físico del dispositivo.

Seguridad en IoT

Los dispositivos IoT (Internet of Things) pueden presentar riesgos debido a sus características y a la gran cantidad de dispositivos conectados.

- Algunos problemas frecuentes son:
- Contraseñas predeterminadas.
- Firmware desactualizado.
- Falta de cifrado.
- Servicios innecesarios expuestos.
- Vulnerabilidades conocidas.
- Falta de actualizaciones de seguridad.
- Configuraciones inseguras.
- Firmware

El firmware es el software integrado que permite controlar el funcionamiento básico de un dispositivo.

Un firmware desactualizado puede contener vulnerabilidades conocidas que podrían ser aprovechadas por un atacante.

Riesgos para la continuidad operativa

La continuidad operativa busca que una organización pueda mantener o recuperar sus operaciones después de un incidente. Podemos usar algunos riesgos de ejemplo como lo es:

- Caída de sistemas críticos
- Respaldos inexistentes
- Respaldos que nunca han sido probados
- Dependencia de un único proveedor
- Falta de redundancia
- Ausencia de planes de recuperación

- Fallas de infraestructura

No basta con realizar respaldos; también es necesario probar periódicamente que pueden restaurarse correctamente.

Amenazas emergentes

La evolución tecnológica genera nuevas amenazas y modifica las existentes.

Ataques relacionados con inteligencia artificial

La inteligencia artificial puede utilizarse para automatizar determinadas actividades maliciosas, generar contenido engañoso o mejorar campañas de ingeniería social.

Ataques a la cadena de suministro

Ocurren cuando un atacante compromete un proveedor, componente, software o servicio que posteriormente es utilizado por otras organizaciones.

Deepfakes

- Contenido sintético generado o manipulado mediante técnicas de inteligencia artificial, incluyendo:
- Video.
- Audio.
- Imágenes.
- Clonación de voz.

Pueden utilizarse para suplantación de identidad y campañas de ingeniería social.

Malware polimórfico

Malware capaz de modificar determinadas características de su código o estructura para dificultar su detección mediante mecanismos de seguridad tradicionales.

Cryptojacking

Uso clandestino de los recursos computacionales de dispositivos comprometidos para realizar minería de criptomonedas.

Comando netstat -a

El comando:

netstat -a

permite visualizar conexiones de red y puertos que se encuentran en diferentes estados, incluyendo puertos en escucha y conexiones activas.

Es útil para realizar una revisión básica de las comunicaciones de un equipo.

Importante: netstat -a no es propiamente un escáner de dispositivos conectados a una red. Su función principal es mostrar información de conexiones y puertos del equipo donde se ejecuta.

Modelo OSI

El modelo OSI (Open Systems Interconnection) es un modelo conceptual utilizado para comprender cómo se comunican los dispositivos dentro de una red.

Está dividido en siete capas.

Su principal objetivo es separar las funciones de comunicación en diferentes niveles. Esto permite analizar problemas de red y comprender la función de diferentes protocolos y dispositivos.

- Principio de división

  Cada capa realiza determinadas funciones y proporciona servicios a la capa superior.

- Independencia

  Los cambios realizados en una capa pueden realizarse sin tener que modificar necesariamente todas las demás capas.

Las siete capas del modelo OSI

7. Aplicación

Es la capa más cercana al usuario. Proporciona servicios de red utilizados por las aplicaciones.

Ejemplos:

- HTTP
- HTTPS
- FTP
- DNS
- SMTP

6. Presentación

Se encarga de aspectos relacionados con la representación de los datos.

Entre sus funciones pueden encontrarse:

- Formato
- Codificación
- Cifrado
- Compresión

5. Sesión

Gestiona las sesiones de comunicación entre aplicaciones que pueden encargarse de funciones como:

- Establecer sesiones
- Mantenerlas
- Finalizarlas
- Sincronizar la comunicación

4. Transporte

Proporciona comunicación entre procesos y utiliza puertos para identificar servicios.

Entre sus funciones están:

- Segmentación
- Control de flujo
- Control de errores
- Fiabilidad de la comunicación
- Protocolos importantes:
    - TCP.
    - UDP.

3. Red

Se encarga del direccionamiento lógico y enrutamiento de los paquetes entre diferentes redes.

El protocolo más representativo es IP.

Los routers trabajan principalmente en esta capa.

2. Enlace de datos

Gestiona la comunicación dentro de un enlace de red y utiliza direcciones físicas como las direcciones MAC.

La unidad de datos de esta capa es la trama.

Los switches Ethernet trabajan principalmente en esta capa.

1. Física

Es la capa encargada de transmitir los bits mediante un medio físico.

Incluye elementos como:

- Cables.

- Conectores.
- Señales eléctricas.
- Señales ópticas.
- Señales de radio.
- Características físicas de transmisión.

En esta capa no se interpreta el contenido de los datos; se trabaja con la transmisión de señales y bits.

Bibliografía:

International Organization for Standardization. (1994). Information technology—Open Systems Interconnection—Basic Reference Model: The Basic Model (ISO/IEC 7498-1:1994). https://www.iso.org/standard/20269.html

Kaspersky. (s. f.). Clasificaciones de malware: Tipos de amenazas de malware. https://latam.kaspersky.com/resource-center/threats/malware-classifications

Kaspersky. (s. f.). What is malware? https://usa.kaspersky.com/resource-center/definitions/what-is-malware

Lyon, G. F. (2022). Nmap network scanning: The official Nmap project guide to network discovery and security scanning. Nmap Project. https://nmap.org/book

National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST Cybersecurity White Paper 29). U.S. Department of Commerce. https://doi.org/10.6028/NIST.CSWP.29

National Institute of Standards and Technology. (2024). NIST Cybersecurity Framework 2.0: Resource & Overview Guide (NIST Special Publication 1299). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.1299

Shodan. (s. f.). What is Shodan? Shodan Help Center. https://help.shodan.io/the-basics/what-is-shodan

Advanced Port Scanner. (s. f.). Advanced Port Scanner: Explorador de puertos rápido y gratuito. https://www.advanced-port-scanner.com